Segurança da Informação

Aula 0

Gilmar Gomes do Nascimento

Instituto Federal do Tocantins
Campus Formoso do Araguaia

10 de agosto de 2026



Formação Acadêmica

- Ciência da Computação - UFT 2009 – 2014
- Especialização Lato Senso - ESAB - 2019
- Especialização Lato Senso - Focus - 2021
- Mestrado em Ciência da Computação - UTFPR - 2024 - atualmente



Atuação Profissional

- Instrutor de Informática - SENAC - TO - 2014, 2015
- Professor de Informática - Colégio da Polícia Militar - TO - 2015 - 2016
- Analista de Suporte - Justiça Federal - TO - 2017
- Professor substituto EBTT - IFTO - Campus Colinas do Tocantins - 2017 - 2019
- Professor EBTT - IFAM - Campus Boca do Acre - 2021 - 2026
- Professor EBTT - IFTO - Campus Formoso do Araguaia - 2026



Ementa

Ementa					
Unidade Curricular:	**ATT12 - Segurança da Informação**				
Série:	3ª	**CH Presencial (horas):**	48 h	**CH Teórica (%):**	50%
CH Total (horas):	60h	**CH a Distância (horas):**	12 h	**CH Prática (%):**	50%
HABILIDADES					
Prover segurança da informação.					
CONTEÚDOS					
Conceitos fundamentais de Segurança da Informação; Princípios de confidencialidade, integridade e disponibilidade; Tipos de ameaças e vulnerabilidades; Técnicas de criptografia e autenticação; Políticas de segurança e normas de segurança da informação.					
Controle de acesso e gerenciamento de identidades; Segurança em redes de computadores; Sistemas de detecção e prevenção de intrusões; Segurança em ambientes de nuvem; Plano de continuidade de negócios e recuperação de desastres.					
BIBLIOGRAFIA					
BÁSICA	HAYAMA, Marcelo Massayuki. **Montagem de redes locais**: prático e didático. São Paulo: Érica, 2002.				
	LYRA, Maurício Rocha. **Segurança e auditoria em sistema de informação**. São Paulo: Ciência Moderna, 2008.				
COMPLEMENTAR	ALBUQUERQUE, F. **TCP/IP Internet protocolos & tecnologias**. 3. ed. Rio de Janeiro: Axcel Books, 2001.				
	COMER, D. E. **Redes de computadores e internet**. 2. ed. Porto Alegre: Bookman, 2001.				
	NORTHCUTT, S.; ZELTSER, L. **Desvendando segurança em redes**. São Paulo: Campus, 2002.				
	SOARES, Luis Fernando Gomes; LEMOS, Guido; COLCHER, Sérgio. **Redes de computadores**: das LAN's, MAN's e WAN's às Redes ATM. São Paulo: Campus, 1995.				

Netiqueta

Quando a gente era mais novo, era muito martelado regras de etiqueta online e como se proteger na Internet

Não falar com desconhecido, evitar usar seu próprio nome, não revelar dados pessoais, etc

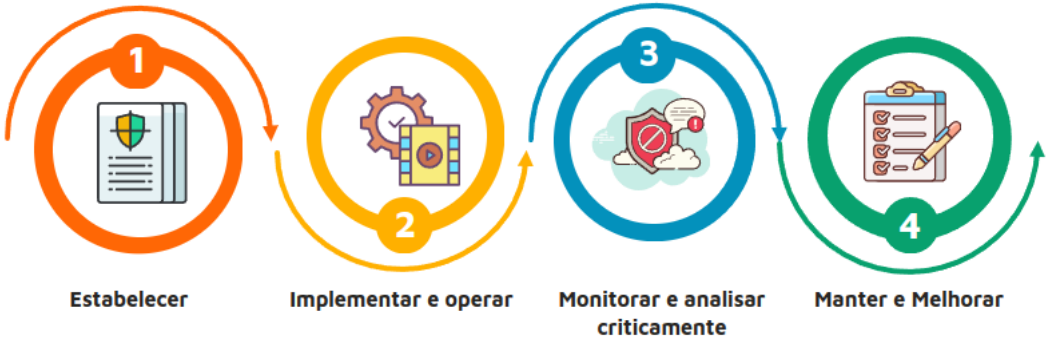


Introdução a Segurança da Informação I

Segurança da Informação (SI) refere-se ao conjunto de práticas, políticas e medidas adotadas para proteger os dados e informações contra acesso não autorizado, uso indevido, modificação, divulgação ou destruição não autorizada. A SI busca garantir a confidencialidade, integridade e disponibilidade das informações, bem como a autenticidade e não repúdio.



Introdução a Segurança da Informação II



Quem é responsável pela segurança?

- Usuário
- Técnico Informática
- Desenvolvedor/administrador
- Gerente de TI

Resumo

Todo mundo é responsável!



Usuário

- **Senha forte e intransferível**
- **Desconfiar sempre**
- **Bloqueio físico**
- **Uso consciente da internet e dos dispositivos**
- **Fotos em locais sensíveis**

Fato

90% dos ataques bem-sucedidos começam com erro humano.



- **Backup e inventário**
- **Agir com ética**
- **Não usar softwares piratas**
- **Orientar usuários e a instituição**
- **Registro de incidentes**



Desenvolvedor/Administrador I

- **Desenvolvimento Seguro**
- **Controle de acesso**
- **Monitoramento ativo**
- **Gerenciamento de patches**



Desenvolvedor/Administrador II

- **Cuidado com códigos externos**
- **Segurança em APIs**

Atenção

Código funcional não significa código seguro!



Gerente de TI I

- **Gestão de Projetos e Modelo de Negócio** - Alinhe a segurança aos objetivos estratégicos da instituição.
- **Alocação de Recursos** - Defenda orçamento para ferramentas, treinamentos e especialistas.
- **Políticas e Procedimentos** - Crie e faça cumprir a Política de Segurança da Informação (PSI).



Gerente de TI II

- **Cultura Organizacional** - Promova uma cultura onde segurança é vista como facilitadora, não obstáculo.
- **Gestão de Riscos** - Identifique, avalie e mitigue riscos continuamente.
- **Plano de Continuidade** - Garanta um plano de recuperação em caso de incidentes.



DevSecOps I

DevSecOps significa desenvolvimento, segurança e operações. É uma abordagem a cultura, automação e design da plataforma que integra segurança como uma responsabilidade compartilhada em todo o ciclo de vida da TI.



DevSecOps II

Shift Left

A segurança é pensada no início do projeto, não no final

Automação contínua

Testes de segurança automatizados a cada versão do código

Quebra de Silos

Desenvolvedores, Segurança e Operações trabalham juntos, com métricas e objetivos comuns



Modelo de Negócio da instituição

Quais são os dados sigilosos?



Área de atuação I

- Serviço público
- Iniciativa privada
- Terceiro setor



Área de atuação II



Área de atuação III

- Técnico em Laboratório
- Técnico em Informática



Estrutura de Gestão de Segurança da Informação do IFTO

Instrução Normativa

- Gestor de Segurança da Informação;
- Gestor de Tecnologia da Informação;
- Encarregado de Tratamento de Dados Pessoais;
- Responsável pela Unidade de Controle Interno;
- Comitê de Segurança da Informação; e
- Equipe de Tratamento e Resposta a Incidentes Cibernéticos.

Confidencialidade

Refere-se à propriedade de um sistema de não permitir que as informações sejam disponibiliza-das ou divulgadas a indivíduos, entidades ou processos não autorizados (ISO 27.000, 2018). Assim, a confidencialidade visa preservar o acesso do conteúdo aos(às) usuários(as) explicitamente definidos(as)

Disponibilidade

Característica de um sistema que possibilita o acesso à informação sempre que o(a) usuário(a) necessitar (ISO 27.000, 2018). Sob esse enfoque, a disponibilidade visa manter as informações sempre acessíveis, por intermédio das aplicações e sistemas operacionais.



Integridade

Essa particularidade do sistema confere precisão e completude à informação, evitando que conteúdo informacional seja alterado ou corrompido. O backup e os métodos criptográficos contribuem para a manutenção da integridade das informações, evitando sua destruição e alteração, respectivamente (ISO 27.000, 2018).

Privacidade

A Lei Geral de Proteção de Dados (LGPD), identificada como Lei n. 13.709/2018, aborda o tratamento de dados pessoais, dispostos em meio físico ou digital, feito por pessoa física ou jurídica, de direito público ou privado, englobando um amplo conjunto de operações que podem ocorrer em meios manuais ou digitais (GOVERNO FEDERAL DO BRASIL, 2018)



Controles

Os controles são ações realizadas para a mitigação dos riscos. Cada atividade desempenhada pela organização tem um risco associado, denominado risco inerente, que após a aplicação de controles poderá ter a probabilidade e/ou o impacto diminuídos, sendo denominado, então, risco residual (ABNT NBR ISO/IEC 27005, 2019).

Ameaças

Uma ameaça tem o potencial de comprometer ativos, tais como: informações, processos e sistemas e, por isso, também as organizações. Ameaças podem ser de origem natural ou humana e podem ser acidentais ou intencionais. Convém que tanto as fontes das ameaças acidentais quanto das intencionais sejam identificadas. Uma ameaça pode surgir de dentro ou de fora da organização e pode se concretizar em um ataque (ABNT NBR ISO/IEC 27005, 2019).



Vulnerabilidades

Segundo a ISO/IEC 27000:2018, vulnerabilidade é a fraqueza de um ativo ou controle que pode ser explorada por uma ou mais ameaças (ISO 27.000, 2018). Sendo assim, as vulnerabilidades devem ser mapeadas e mitigadas para manter as aplicações e os sistemas seguros.

Risco

Risco é o efeito da incerteza no alcance dos objetivos. Um efeito é um desvio em relação ao esperado, podendo ser positivo e/ou negativo. O risco em segurança da informação é muitas vezes expresso em termos de uma combinação de consequências de um evento e a probabilidade de ocorrência.

